

SG/Send PKI ↔ StackGuard NHI: Architecture Mapping & Analysis

Prepared by: Architect, SGraph Send Team

Version: v0.13.12

Date: 10 March 2026

Context: Mapping SG/Send PKI capabilities (existing and proposed) to StackGuard's Non-Human Identity platform

1. StackGuard in One Paragraph

StackGuard's core thesis is the **80:1 ratio** — for every human identity, there are 80 Non-Human Identities (service accounts, API keys, tokens, certificates). Their lifecycle is: **Discover** → **Contextualize & Prioritize** → **Remediate** → **Govern & Monitor**. Their stated pain points are: no NHI inventory, zombie identities, over-privileged access, secret spillage, and no lifecycle management.

The key architectural observation: **StackGuard treats NHI security as a detection and remediation problem**. Find the secrets, classify them, rotate them, govern them. They are working within the world of shared secrets.

2. The Core Tension Worth Naming

StackGuard's entire business exists because NHIs use **shared secrets** (bearer tokens, API keys, passwords) that can be stolen, leaked, or forgotten. Their scanning, rotation, and governance tooling is built on the assumption that secrets exist and need managing.

SG/Send's PKI approach — especially the proposed pieces — represents a path to a world where **those shared secrets don't need to exist at all**. That's not a threat to StackGuard; it's a migration path their customers need.

3. Mapping: What EXISTS Now vs. What's Proposed

Tier 1 — EXISTS Today (code-verified at v0.10.49)

SG/Send Capability	Endpoint / Component	StackGuard Relevance
RSA key registry	<code>POST /keys/publish</code> , <code>GET /keys/lookup/{code}</code>	A cryptographic NHI inventory. An NHI is identified by a public key fingerprint — nothing to steal.
Transparency log	<code>GET /keys/log</code>	Tamper-evident audit trail of all key operations. Feeds StackGuard's Govern & Monitor phase with cryptographic evidence rather than log scraping.
Explicit revocation	<code>DELETE /keys/unpublish/{code}</code>	StackGuard's zombie NHI problem exists because revocation is hard and unverifiable. Key

SG/Send Capability	Endpoint / Component	StackGuard Relevance
		unpublishing is atomic, auditable, and verifiable by any party.
Fingerprint-based lookup	GET /users/fingerprint/{fp}	An NHI can be identified by its public key fingerprint — no secret required for identification.
User bound to PKI key at creation	POST /users/create	Every identity (human or machine) is anchored to a cryptographic key at creation. Foundation for NHI identity that doesn't rely on secrets.
PKI UI tools	pki-keys, pki-encrypt, pki-contacts, key-publish, key-lookup, key-registry, key-log	Full admin UI for key lifecycle management. Can be extended to govern machine identities directly.

Tier 2 — PROPOSED (not yet in code — labelled explicitly)

SG/Send Proposal	What It Enables	StackGuard Connection
Authentication by decryption	A service proves its identity by decrypting a challenge encrypted with its public key	Eliminates the entire category of API keys and bearer tokens StackGuard has to scan for. No secret to leak, no rotation needed, no spillage possible.
sgraph.ai/verify + .well-known/sg-identity.json	Public, third-party verifiable identity anchored to DNS	StackGuard can verify an NHI's claimed identity against a public record without a central authority. Integrates directly into governance workflows.
sg-panel-identity (per-component PKI)	Each microservice or Web Component gets its own scoped PKI identity	Direct answer to NHI proliferation. Instead of one overprivileged shared service account, each component has a scoped cryptographic identity that StackGuard can discover and govern.
Per-file PKI	Each document or artifact has cryptographic provenance	Compliance artifacts have a verifiable custody chain. StackGuard customers in regulated industries can prove what touched what.
Signed communications	Messages provably originate from a specific identity	Eliminates impersonation between services. StackGuard currently has to detect impersonation; signed comms make it architecturally impossible.
Agent identity framework	AI agents carry verifiable cryptographic identities	As agentic AI proliferates, agents become a new category of NHI. SG/Send's identity model applies directly to governing which agents can access what.

4. Three Conversation Angles

Angle 1: SG/Send PKI as the identity substrate StackGuard governs

Right now StackGuard discovers NHIs by scanning for secrets. If NHIs instead publish RSA keys to a registry (like SG/Send's), StackGuard's discovery phase becomes a key registry query rather than a secret scan. The transparency log becomes their governance audit trail — with cryptographic integrity, not log scraping. This is a clean **integration story**.

Angle 2: "Authentication by decryption" as the migration path StackGuard's customers need

StackGuard's customers want to reduce their NHI attack surface. Today's answer is "rotate your tokens more often." The better answer is "replace your tokens with cryptographic identity so there's nothing to rotate." SG/Send is building the proof-of-concept of that pattern — the workspace → vault → CLI flow already demonstrates that real cross-system workflows can operate with **zero shared secrets**. That's the world StackGuard's customers want to live in.

Angle 3: StackGuard governing the sg-panel-identity model at scale (*PROPOSED*)

When sg-panel-identity ships, every component in SG/Send's architecture will have its own PKI identity. That is the microservice identity model StackGuard needs to govern at scale. There is a world where StackGuard's platform consumes a key registry like SG/Send's to maintain an NHI inventory with zero scanner overhead — the identities self-register, self-describe, and self-revoke. No scanning required.

5. What's Proven vs. What's the Direction

Category	Status
RSA key registry (publish, lookup, revoke, transparency log)	EXISTS — code-verified
Fingerprint-based identity lookup	EXISTS — code-verified
User identity bound to PKI key	EXISTS — code-verified
PKI admin UI (full key lifecycle)	EXISTS — code-verified
Cross-system zero-shared-secret workflow (workspace → vault → CLI)	EXISTS — milestone verified 4 March 2026
Authentication by decryption	PROPOSED — not yet built
sgraph.ai/verify + DNS identity anchoring	PROPOSED — not yet built
sg-panel-identity (per-component PKI)	PROPOSED — not yet built
Per-file PKI / signed communications	PROPOSED — not yet built
Agent identity framework	PROPOSED — not yet built

The conversation with StackGuard should be framed as: "*here is what we have proven works, and here is the architectural direction we are moving toward*" — not as a claim that the full vision is shipped.

6. The One-Line Summary for the Meeting

SG/Send has built a working zero-knowledge encrypted file and vault system with a live PKI key registry and transparency log. The next phase extends that PKI model to become the identity substrate for machine and agent identities — the exact problem StackGuard is solving from the detection side. The intersection is: SG/Send provides cryptographic NHI identity; StackGuard provides governance, lifecycle management, and remediation over those identities.

SGraph Send — Architect

v0.13.12 — 10 March 2026